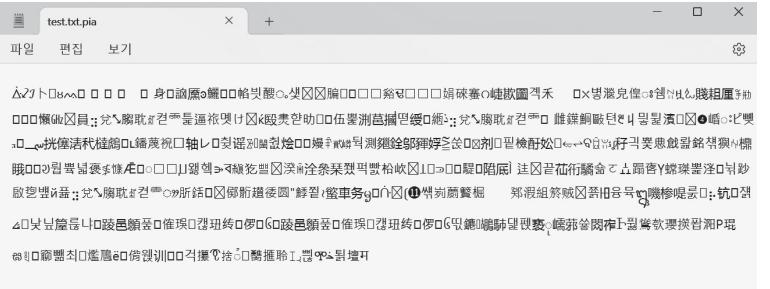
SECTION 1

엔드포인트 보안

1. 문서 보안(DRM)

DRM은 Digital Rights Management의 약자로 회사 내부에서 사용하는 문서 파일들을 암호화하고 중앙에서 통제하는 솔루션이다. 이후에 설명할 보안 솔루션도 마찬가지겠지만 일반적으로 업무 PC에 보안 솔루션의 에이전트(Agent)가 설치되며, 해당 에이전트와 통신하는 서버로 구성된다. 설치만 되어 있는 것처럼 보이겠지만, 알게 모르게 DRM 에이전트가 제 역할을 수행한다. DRM이 설치된 업무 PC의 문서 파일이나 이미지 파일들이 만약 암호화되어 저장되어 있다면, [그림 2-1]과 같이 파일 아이콘에 자물쇠 아이콘이 추가되어 보인다.

[그림 2-1] 암호화 걸린 아이콘



[그림 2-2] 암호화된 문서 내용

외부에서 문서 파일을 다운받거나 혹은 새로운 문서 파일을 생성/편집하는 경우 DRM 에이전트는 이 행동을 탐지하여 해당 문서를 실시간으로 암호화한다. 암호화된 파일은 DRM 에이전트가 없는 환경에서 파일을 열어보거나 내부 데이터를 확인할 수 없다. 또한 DRM이 지원하지 않는 프로그램으로 강제로 파일을 열어본다면 [그림 2-2]와 같이 데이터가 깨져서 보인다.

“ 굳이 DRM을 써야 하나요? 망분리도 되어 있잖아요. ”

회사에서 업무를 하다 보면 문서 파일을 밖으로 반출하거나 암호화를 해제해야 하는 상황이 반드시 있다. 결국 사람이 하는 일이기 때문에 실수가 발생하거나, 보안 사고로 이어질 수 있다. 사고가 발생했다는 사실 자체만으로 금융회사의 브랜드 이미지에 큰 타격을 주기 때문에, 외부

에 있는 해커들이 우리의 문서 파일을 만약 탈취해 가더라도 2차 피해가 발생하지 않도록 하는 문서 암호화는 최소한의 장치다.

보안적인 측면 외에도 금융회사는 법의 영향을 굉장히 많이 받기 때문에 법적인 이유에서도 DRM을 반드시 사용해야 한다. DRM을 반드시 사용하라고 직접적으로 법에 명시되어 있지는 않지만, 법에서 요구하는 내용들을 보면 DRM을 쓸 수밖에 없다.

개인정보 보호법

제24조(고유식별정보의 처리 제한) ① 개인정보처리자는 다음 각 호의 경우를 제외하고는 법령에 따라 개인을 고유하게 구별하기 위하여 부여된 식별정보로서 대통령령으로 정하는 정보(이하 "고유식별정보"라 한다)를 처리할 수 없다.

1. 정보주체에게 제15조제2항 각 호 또는 제17조제2항 각 호의 사항을 알리고 다른 개인정보의 처리에 대한 동의와 별도로 동의를 받은 경우

2. 법령에서 구체적으로 고유식별정보의 처리를 요구하거나 허용하는 경우

② 삭제 <2013. 8. 6.>

③ 개인정보처리자가 제1항 각 호에 따라 고유식별정보를 처리하는 경우에는 그 고유식별정보가 분실 · 도난 · 유출 · 위조 · 변조 또는 훼손되지 아니하도록 대통령령으로 정하는 바에 따라 암호화 등 안전성 확보에 필요한 조치를 하여야 한다. <개정 2015. 7. 24.>

제29조(안전조치의무) 개인정보처리자는 개인정보가 분실 · 도난 · 유출 · 위조 · 변조 또는 훼손되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적 · 관리적 및 물리적 조치를 하여야 한다.

개인정보 보호법에서는 개인정보처리자가 고유식별정보를 처리하려는 경우 대통령령에 따라 안전성 확보에 필요한 조치를 수행해야 한다. 개인정보처리자는 회사를 말하며, 개인정보취급자는 개인정보처리자의 지휘·감독을 받는 임직원이 해당된다.

고유식별정보의 범위와 안전성 확보 조치에 대한 내용은 개인정보 보호법 시행령에서 찾아볼 수 있다.

개인정보 보호법 시행령

제19조(고유식별정보의 범위) 법 제24조제1항 각 호 외의 부분에서 "대통령령으로 정하는 정보"란 다음 각 호의 어느 하나에 해당하는 정보를 말한다. 다만, 공공기관이 법 제18조제2항제5호부터 제9호까지의 규정에 따라 다음 각 호의 어느 하나에 해당하는 정보를 처리하는 경우의 해당 정보는 제외한다. <개정 2016. 9. 29., 2017. 6. 27., 2020. 8. 4.>

1. 「주민등록법」 제7조의2제1항에 따른 주민등록번호
2. 「여권법」 제7조제1항제1호에 따른 여권번호
3. 「도로교통법」 제80조에 따른 운전면허의 면허번호
4. 「출입국관리법」 제31조제5항에 따른 외국인등록번호

제21조(고유식별정보의 안전성 확보 조치) ① 법 제24조제3항에 따른 고유식별정보의 안전성 확보 조치에 관하여는 제30조를 준용한다. 이 경우 "법 제29조"는 "법 제24조제3항"으로, "개인정보"는 "고유식별정보"로 본다.

제30조(개인정보의 안전성 확보 조치) ① 개인정보처리자는 법 제29조에 따라 다음 각 호의 안전성 확보 조치를 해야 한다. <개정 2023. 9. 12.>

…중략…

4. 개인정보를 안전하게 저장 · 전송하는데 필요한 다음 각 목의 조치

가. 비밀번호의 일방향 암호화 저장 등 인증정보의 암호화 저장 또는 이에 상응하는 조치

나. 주민등록번호 등 보호위원회가 정하여 고시하는 정보의 암호화 저장 또는 이에 상응하는 조치

다. 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제2조제1항제1호에 따른 정보통신망을 통하여 정보주체의 개인정보 또는 인증정보를 송신 · 수신하는 경우 해당 정보의 암호화 또는 이에 상응하는 조치

라. 그 밖에 암호화 또는 이에 상응하는 기술을 이용한 보안조치

…중략…

③ 제1항에 따른 안전성 확보 조치에 관한 세부 기준은 보호위원회가 정하여 고시한다. <개정 2013. 3. 23., 2014. 11. 19., 2017. 7. 26., 2020. 8. 4.>

금융회사에서는 일상적인 업무를 할 때도 개인정보, 고유식별정보가 문서 파일이나 동영상 파일, 음성 파일에 포함될 수 있다. 특히 문서 파일의 경우 대량의 데이터가 들어가기 쉽기 때문에 모든 문서 파일은 암호화 처리를 하는 것이 담당자 입장에서 심리적으로 편하다. 안전성 확보 조치에 관한 세부 기준은 개인정보의 안전성 확보조치 기준에서 확인할 수 있다.

개인정보의 안전성 확보조치 기준

제7조(개인정보의 암호화) ① 개인정보처리자는 비밀번호, 생체인식정보 등 인증정보를 저장 또는 정보통신망을 통하여 송 · 수신하는 경우에 이를 안전한 암호 알고리즘으로 암호화하여야 한다. 다만, 비밀번호를 저장하는 경우에는 복호화되지 아니하도록 일방향 암호화하여 저장하여야 한다.

② 개인정보처리자는 다음 각 호의 해당하는 이용자의 개인정보에 대해서는 안전한 암호 알고리즘으로 암호화하여 저장하여야 한다.

1. 주민등록번호

2. 여권번호

3. 운전면허번호

4. 외국인등록번호

5. 신용카드번호

6. 계좌번호

7. 생체인식정보

③ 개인정보처리자는 이용자가 아닌 정보주체의 개인정보를 다음 각 호와 같이 저장하는 경우에는 암호화하여야 한다.

1. 인터넷망 구간 및 인터넷망 구간과 내부망의 중간 지점(DMZ : Demilitarized Zone)에 고유식별정보를 저장하는 경우

2. 내부망에 고유식별정보를 저장하는 경우(다만, 주민등록번호 외의 고유식별정보를 저장하는 경우에는 다음 각 목의 기준에 따라 암호화의 적용여부 및 적용범위를 정하여 시행할 수 있다)

…중략…

⑤ 개인정보처리자는 이용자의 개인정보 또는 이용자가 아닌 정보주체의 고유식별정보, 생체인식정보를 개인정보취급자의 컴퓨터, 모바일 기기 및 보조저장매체 등에 저장할 때에는 안전한 암호 알고리즘을 사용하여 암호화한 후 저장하여야 한다.

…생략…

개인정보를 저장하기 위해 안전한 암호 알고리즘으로 암호화하여야 한다. 대부분의 DRM 솔루션은 안전한 암호 알고리즘을 지원하고 있다.

" DRM은 어떻게 실시간으로 문서 파일을 암호화해요? "

DRM은 크게 후킹과 커널의 두 가지 방식으로 나뉜다. 후킹 방식에서 후킹은 해킹할 때도 사용하는 기술로 중간에 끼어들어 가로채는 것을 의미한다. 이 방식은 애플리케이션 간에 주고받는 데이터를 중간에서 가로채 내가 원하는 동작을 수행하도록 할 수 있기 때문에 악성코드나 보안 솔루션의 두 영역에서 모두 자주 사용하는 기술이다.

DRM은 우리가 문서 파일을 작성하고 저장할 때 DRM 에이전트가 중간에 끼어들어 암호화하는 형태다. 이런 방식은 문서를 편집하는 프로그램(ex. 한컴오피스, MS오피스)이 업데이트되거나, DRM이 지원하지 않는 문서 편집기의 경우 우리가 원하는 대로 암호화가 되지 않는다. 뿐만 아니라 중간에 끼어들기 때문에 다른 후킹 방식의 보안 솔루션과 충돌이 날 수도 있으며 주기적으로 DRM 패치 작업을 해줘야 한다. 간단한 문제로 보일 수 있겠지만, 업무 PC나 소프트웨어를 담당하는 부서와 소통이 원활하지 않다면 DRM이 지원하지 않는 문서 편집기를 배포할 수 있고, 현업 관련 전화가 계속 올 수 있으니 참고하길 바란다.

커널 방식은 후킹 방식처럼 애플리케이션 업데이트 여부 혹은 미지원하는 문서 편집기로부터 자유로우며 다른 프로그램과 충돌이 적다. 하지만 DRM 솔루션 장애 시, 후킹 방식은 프로그램이 멈추는 현상이 대부분인 반면에 커널 방식은 블루스크린이 발생하여 업무 PC를 아예 사용하지 못할 수 있다.

각 방식마다 장단점이 있기 때문에 어떤 것이 더 좋고 나쁜지 정답은 없다. DRM 솔루션을 도입할 때 개념 증명(Proof of Concept, PoC)[1]이나 벤치마킹 테스트(Bench Marking Test, BMT)[2]를 통해 금융회사에 잘 맞

1 솔루션이 제시한 기능이 실제로 가능한지를 입증하는 프로젝트

2 동일한 환경에서 여러 솔루션의 성능 비교를 통해 평가하는 것

는 솔루션을 가려내면 된다. 필자 경험상 대부분 후킹 방식의 DRM 솔루션을 주로 사용한다.

" 개인정보, 고유식별정보가 들어간 파일만 암호화하면 안 되나요? "

개인정보가 들어간 파일만 탐지해서 암호화를 적용할 수도 있으며, 금융회사의 정책마다 다르기 때문에 정답이 존재하지 않는다. 필자의 경험으로는 그동안 다녔던 금융회사들은 내부망에 있는 모든 문서 파일을 실시간 암호화했다. 업무와 관련해 다양한 형식으로 개인정보가 문서 파일 내에 존재하기 때문에 보안 홀을 만들지 않기 위해서다.

이름	전화번호	주민번호	익명정보
홍길동	02-1234-5678	911223-1234567	서울특별시 종로구

[그림 2-3] 사람이 생성한 개인정보 파일

	A	B	C
1	이름, 전화번호, 주민번호, 주소		
2	홍길동, 0212345678, 199112231234567	서울특별시	종로구

[그림 2-4] 시스템에서 생성한 개인정보 파일

[그림 2-3]과 같이 임직원의 업무 스타일에 따라 혹은 [그림 2-4]와 같이 해당 파일을 생성하는 시스템에 따라 저장될 수 있는 데이터의 형식이 다양하게 존재한다. DRM 솔루션이 개인정보와 고유식별정보를 나

름대로 탐지하지만, 모든 형태의 데이터를 구분하기엔 어려움이 있다.

뒷장의 개인정보 검출 내용에서 자세히 설명하겠지만 탐지하는 정보가 많아질수록 잘못 탐지하는 경우가 많아 담당자가 확인해야 하는 내용들이 많아진다. 물론 정형화된 패턴이 있는 데이터들은 정규식을 활용하여 탐지율을 높일 수 있다. 정규식이란 문자열의 일정한 패턴을 표현하는 일종의 형식 언어로 특정 시스템에 정규식 패턴을 등록할 수 있다.

```
KV134 22933 8201012345678 02 333485
```

[그림 2-5] 샘플 전문 파일 내용

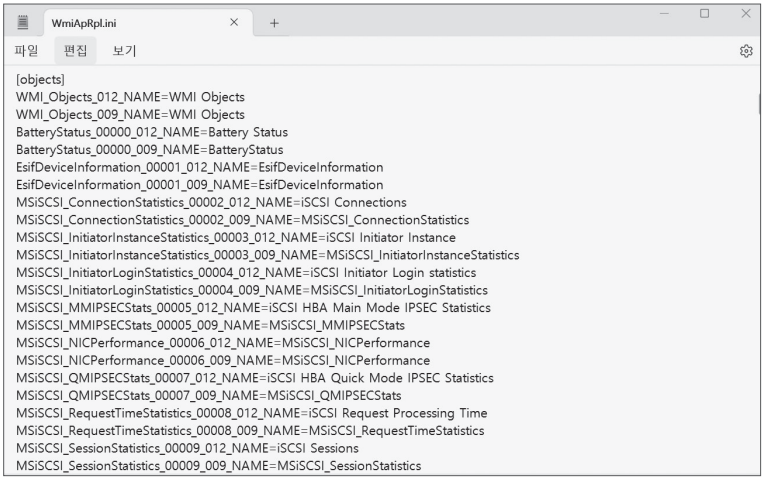
[그림 2-5]에서 DRM은 숫자 사이에 전화번호가 있는지 여부를 알 수가 없다. 이런 경우 정규식을 통해 전화번호를 알게끔 해줄 수 있다. 금융보안 담당자가 정규식을 직접 만들어도 되지만, 우리보다 유능한 솔루션 엔지니어와 담당 연구소가 있으니 그들에게 요청해서 받으면 된다. 혹시 정규식 개발이 궁금하다면 인터넷에 검색해보면 된다.

문자열에 대해 설명했지만 문서 파일에 문자만 있는 것은 아니다. 문서에 신분증 사진이 들어 있는 경우도 있기 때문에 개인정보, 고유식별정보가 들어간 파일만 암호화하게 되면 이런 문서들은 암호화를 놓치게 되고 법령 위반으로 이어질 수 있다.

" 그럼 문서 형태의 파일은 모두 암호화하면 되겠네요? "

안타깝지만 모든 문서 형태의 데이터를 암호화할 순 없다. 프로그램들은 실행될 때 참조하는 설정값을 문서 편집기로 열어볼 수 있는 .ini,

.dat, .log 등의 형태로 저장한다. 대부분의 사용자들은 이용하지 않는 확장자지만 실제로 이러한 파일을 메모장으로 열어보면 일반 텍스트 파일처럼 열어서 데이터를 볼 수 있다.



[그림 2-6] 설정 내용이 들어간 ini 파일

만약 이런 설정 파일까지 암호화해버린다면 프로그램이 제대로 실행되지 않거나 로그 내용이 적재되는 순간 프로그램이 멈추는 등 여러 오류가 발생할 수 있다. 또한 윈도우의 경우 Windows 폴더, System 폴더 등 운영체제가 참조하는 폴더도 있기 때문에 확장자나 특정 경로는 DRM이 암호화하지 못하도록 적절히 예외 처리를 하며 관리해야 한다.

또한 타 부서에서 사용하는 프로그램이나 로봇 프로세스 자동화(Robotic Process Automation, RPA)가 스스로 동작하면서 문서 파일을 편집하고 서버에 업로드하는 등 다양한 작업을 하기 때문에 일부 파일은 암호화를 하지 않도록 설정해줘야 하는 경우가 있을 수 있다.

앞에서 말했듯 암호화된 문서를 평문으로 보려면 DRM 에이전트가 있어야 한다. 하지만 서버, 어플라이언스(Appliance)[3] 같은 시스템들은 업무 PC와 동일한 환경이 아니기 때문에 전용 DRM 에이전트를 따로 설치해야 하거나, 혹은 DRM 에이전트 설치가 불가하다. 그러므로 시스템이 업로드된 문서를 처리하기 위해선 문서 파일을 암호화 해제한 후 업로드해야 한다.

이렇게 암호화 해제된 문서 파일이 서버에 업로드된 후 업무 PC에 그대로 남아 있을 수 있기에 주기적으로 강제 암호화하는 정책을 적용해야 한다. 업로드가 빈번하게 일어난다면 DRM API(Application Programming Interface)를 구매함으로써 업로드 시 자동으로 암호화가 해제된 파일을 첨부하도록 연동할 수도 있다. 이 경우 특정 문서 파일이 업로드될 때만 자동으로 해제되므로 PC에는 해제된 파일이 남아 있지 않다.

" 직원이 DRM을 우회하려고 하는데 어쩌죠? "

암호화가 업무상으로 불가한 경우에 대해 알고 있는 직원이 존재한다. IT 부서는 시스템들을 관리하기 때문에 암호화가 걸리지 않는 여러 확장자를 알고 있다. 뿐만 아니라 다른 부서에서도 암호화를 회피하기 위해 확장자를 다르게 변경하거나 공유 폴더에 숨기는 등 다양한 노력을 하기도 한다. 다행히 이들이 악의적인 목적을 갖고 행동하는 것은 아닐 것이다. 업무 효율성을 높이기 위한 목적일 텐데 이러한 보안 홀이 많아질수록 보안 담당자는 주기적으로 로그를 분석하거나, 자체 점검과 같은 다양한 추가 점검을 보다 많이 수행해야 할 것이다.

---

3 특정 서비스만을 위해 만든 SW와 HW가 통합된 장비로 별도의 OS나 SW 설치가 필요 없다.